

PRUEBA TÉCNICA · CIBERSEGURIDAD

Hardening AWS y Cumplimiento

CIS AWS 1.4 · ISO/IEC 27001:2022 · Ley 1581

PREPARADO POR	Lady Marcela Romero Rivero
ROL	Líder de Ciberseguridad
CLIENTE	Simon Movilidad
ESCENARIO	FleetSec S.A.S. — Telemetría de flotas
FECHA	25 de agosto de 2026
VERSIÓN	1.0

CONFIDENCIAL — Exclusivo para Simon Movilidad

Tabla de contenido

Every row links to concrete evidence in this repository. Status: **PASS** (implemented), **FAIL** (gap), **N/A** (out of scope for this deliverable).

#	Control (CIS AWS 1.4)	ISO 27001:2022	Ley 1581	Implementation	Evidence
1	1.4 No root access keys / 1.5 root MFA	A.5.16, A. 8.5	Art. 4 (seguridad)	Config rule <code>root-account-mfa-enabled</code> ; no root keys created	<code>terraform/.../monitoring.tf</code> (config_rules), <code>iam.tf</code>
2	1.8 Password policy ≥14, reuse 24, 90d	A.5.17	Art. 4	<code>aws_iam_account_password_policy</code> (14/90/24)	<code>iam.tf</code>
3	1.16 No <code>AdministratorAccess</code> / wildcards in prod	A.5.15, A. 8.2	Art. 4 (acceso restringido)	Least-privilege ECS roles; scoped S3/KMS/Secrets	<code>iam.tf</code>
4	2.1.1 S3 SSE + 2.1.5 Block Public Access	A.8.24	Art. 4	Account BPA + per-bucket BPA + SSE-KMS CMK	<code>s3.tf</code>
5	2.1.2 S3 deny insecure transport (TLS)	A.8.24	Art. 4	Bucket policy <code>aws:SecureTransport=false</code> deny	<code>s3.tf</code>
6	3.1 CloudTrail enabled all regions	A.8.15	Art. 4	Multi-region trail + mgmt + S3 data events	<code>monitoring.tf</code>
7	3.2 CloudTrail log file validation	A.8.15	Art. 4	<code>enable_log_file_validation = true</code>	<code>monitoring.tf</code>
8	3.4 CloudTrail → CloudWatch Logs	A.8.15, A. 8.16	Art. 4	<code>cloud_watch_logs_group_arn</code> wired	<code>monitoring.tf</code>
9	3.7 KMS CMK rotation enabled	A.8.24	Art. 4	<code>enable_key_rotation = true</code> (RDS/S3/ECS keys)	<code>kms.tf</code>
10	3.8 S3 bucket-level logging	A.8.15	Art. 4	<code>aws_s3_bucket_logging</code> on telemetry + logs	<code>s3.tf</code>
11	4.1 Metric filter: unauthorized API / root	A.8.16	Art. 4	Metric filters + alarms → SNS (root, IAM, SG, KMS, trail)	<code>monitoring.tf</code>
12	4.3 Alarm on root usage	A.8.16	Art. 4	<code>root_login</code> metric filter + alarm	<code>monitoring.tf</code>
13	5.2 No SG ingress 0.0.0.0/0 to 22	A.8.20, A. 8.22	Art. 4	SGs restrict admin ports; Checkov CKV_AWS_24 + CKV2_FLEETSEC_1	<code>securitygroups.tf</code> , <code>checkov/</code>
14	5.3 No SG ingress 0.0.0.0/0 to 3389	A.8.20	Art. 4	Same; Checkov CKV_AWS_25 passes	<code>securitygroups.tf</code>
15	5.4 Default SG restricts all traffic	A.8.20	Art. 4	<code>aws_default_security_group</code> (no rules)	<code>vpc.tf</code>
16	RDS: encryption + Multi-AZ + no public	A.8.24, A. 8.14	Art. 4, Art. 17	CMK, Multi-AZ, <code>publicly_accessible=false</code> , TLS forced	<code>rds.tf</code>
17	GuardDuty enabled (threat detection)	A.5.7 (threat intel), A. 8.16	Art. 4	Detector all-region + S3 + malware + Threat Intel Set	<code>monitoring.tf</code> , <code>detection/threat-intel/</code>
18	Security Hub FSBP + CIS 1.4	A.5.36, A. 8.16	Art. 4	Standards subscriptions FSBP + CIS 1.4.0	<code>monitoring.tf</code>

#	Control (CIS AWS 1.4)	ISO 27001:2022	Ley 1581	Implementation	Evidence
19	AWS Config recorder + managed rules	A.8.9 (config mgmt)	Art. 4	Recorder + 7 managed rules	<code>monitoring.tf</code>
20	WAFv2 on ALB (SQLi, bad inputs, rate, geo)	A.8.20, A. 8.23	Art. 4	WAF managed rules BLOCK + rate limit + geo CO/PE/US	<code>waf.tf</code>
21	Secrets in Secrets Manager (rotation 30d)	A.8.24, A. 5.17	Art. 4	<code>aws_secretsmanager_secret</code> + rotation	<code>rds.tf</code> , remediat V-10
22	Immutable logs (Object Lock COMPLIANCE)	A.8.15, A. 5.28	Art. 4	Object Lock COMPLIANCE on log/ evidence bucket	<code>s3.tf</code>
23	VPC Flow Logs → S3 + CloudWatch	A.8.16, A. 8.20	Art. 4	<code>aws_flow_log</code> ALL traffic	<code>vpc.tf</code>
24	Data masking / PII protection	A.8.11 (NEW 2022)	Art. 4 (minimización)	PII log sanitizer (V-08 remediation)	<code>app/src/lib/pii</code>
25	Secure coding (SDLC)	A.8.28 (NEW 2022)	—	Semgrep custom rules + SAST gate + secure <code>/secure</code> twins	<code>semgrep/</code> , <code>.github/workflows/</code>
26	Incident response process	A.5.24-5.28	Art. 4 + SIC 15 días	IR playbook + Sigma rules + SIC notification path	<code>detection/playbooks/</code>
27	SIC breach notification (15 business days)	A.5.24	Art. 17	Notification path + template + timeline	<code>detection/playbooks/ir-playbook.md</code> §6
28	Cross-region S3 replication	A.8.14	Art. 17	Not implemented (documented accepted risk)	<code>s3.tf</code> checkov:sk CKV_AWS_144

Coverage: 27 PASS / 0 FAIL / 1 N/A (accepted, documented). ≥ 10 controls mapped as required.

ISO 27001:2022 "new-in-2022" controls covered: A.5.7 (threat intel), A.8.9 (config mgmt), A.8.11 (data masking), A.8.16 (monitoring), A.8.23 (web filtering/WAF), A.8.28 (secure coding).